

A security design section

- Task 3 deliverable (Poorvi Bagga)

Authentication Overview

Authentication is the process of verifying that an individual attempting to access a digital service actually controls the devices or credentials associated with their digital identity.

Primary Authentication: Password-Based

How does it work?

Users who log in with a password must enter credentials, such as a username and password, in order to authenticate themselves. Only if their credentials match those in the database will the system grant them access. Users choose a password that typically meets specific requirements, for example, having a character and a digit and being 7 characters long. The system safely stores it with a unique identifier. The system verifies the entered credentials against the credentials stored when a user logs in. The user is granted access if they match the criteria. If not, access is blocked, and the user may need to re-enter their information or reset their password.

Advantage

- Since passwords are the most widely used authentication method, most users are familiar with them. This familiarity lowers support requests and allows a more seamless user experience.
- Password-based authentication is easy to use and less expensive than techniques that require additional hardware or technology. While it still offers a degree of security.
- Passwords are under the user's control and can be reset or changed at any time.

Disadvantage

- Passwords that are weak or used across multiple systems are particularly vulnerable to theft or brute-force attacks.
- Just around one-third of users avoid reusing passwords across platforms, and many choose weak passwords.
- Passwords are frequently forgotten by users, computers containing saved credentials may crash, and hard copies of passwords may be misplaced or stolen.
- Users may find password-based authentication annoying if it requires overly complex passwords or strict guidelines.

Used resources:

<https://www.descope.com/learn/post/password-authentication>

Secondary Authentication: Email One-Time Password (OTP)

How does it work?

OTP, or One-Time Password, is a method of authenticating users using a special password that is used only once. In this user-authentication mode, when a user attempts to access the system, a password is sent to them. This password is valid for a short time. As this password is set to expire soon, users are protected against intruders even if other passwords have been compromised.

Advantage

- Enhancements in security reduction of the chance of password duplication and phishing attacks.
- Enforces regulatory compliance requirements.
- It can be effortlessly integrated with multi-factor authentication systems.

Disadvantage

- Delays in delivery or interception are possible in email OTP systems.
- There is a chance the user will be unable to access the OTPs on their devices if they are lost or go out of range.
- Even phishing attacks may succeed in extracting OTPs from users. If not done efficiently, repeated OTP entry could degrade the user experience.

Used resource: <https://www.loginradius.com/blog/identity/what-is-otp-authentication>

Summary

- Log in using password-based authentication
- Go through 2-factor verification with OTP via email
- This combination ensures strong protection of sensitive health data while the usability across devices assures that authentication is secure and accessible to all users.